

دليل الاستعداد لمقابلة

Cybersecurity GRC

Cybersecurity Governance, Risk & Compliance Interview Guide

أسئلة متوقعة • إجابات نموذجية • سيناريوهات عملية • مصطلحات أساسية

Expected Questions • Model Answers • Practical Scenarios • Core Terminology

إعداد | Prepared by

رامي بن عبدالرحمن الغانمي | **Rami Abdulrhman Alghanmi**

X @Ralghanmi • Snapchat Rmoii • TikTok / Instagram / YouTube @Cyber4alll

كيف تستخدم هذا الدليل | How to Use This Guide

لا تحفظ الإجابات حرفيًا. افهم الفكرة ثم عدّل المثال بما يتوافق مع خبرتك الحقيقية والجهة والقطاع والوصف الوظيفي. الأفضل أن تكون إجابتك مباشرة وتحتوي على منهج واضح ومثال أو نتيجة متى ما أمكن.

Do not memorize the answers word for word. Understand the reasoning, then adapt each answer to your real experience, the organization, its sector, and the job description. Strong answers are direct, structured, and supported by a relevant example or outcome whenever possible.

معادلة الإجابة المهنية | Professional Answer Formula

السياق ← الخطر ← المتطلب ← الضابط ← الدليل ← الفجوة ← المعالجة ← المتابعة

Context → Risk → Requirement → Control → Evidence → Gap → Remediation → Monitoring

ركّز على ما Result والنتيجة، Action الإجراء، Task المهمة، Situation الموقف: STAR في الأسئلة السلوكية استخدم فعلته أنت، ثم اختتم بأثر واضح أو درس مهني.

For behavioral questions, use STAR: Situation, Task, Action, and Result. Focus on your own contribution and close with a measurable outcome or professional lesson.

Expected Technical and GRC Questions | الأسئلة التخصصية المتوقعة

القسم التالي يجمع الأسئلة الأكثر شيوعاً مع الهدف من كل سؤال وإجابة نموذجية باللغتين. خصص الإجابات قبل المقابلة ولا تضيف خبرة لم تمارسها.

The following section includes common questions, what each one assesses, and model answers in both languages. Tailor the responses before the interview and never claim experience you do not have.

عرّفنا بنفسك

Tell us about yourself

ما الذي يقيسه السؤال: قدرتك على تقديم نفسك وربط خلفيتك بالوظيفة خلال وقت قصير

What it assesses: Your ability to present a concise, role-relevant professional story.

إجابة نموذجية: أنا متخصص في الأمن السيبراني ومهتم بمجال الحوكمة والمخاطر والامتثال لأنه يجمع بين فهم الأعمال والمتطلبات التنظيمية والجانب التقني. لدي معرفة في تقييم المخاطر وتحليل الضوابط وكتابة السياسات وجمع الأدلة ومتابعة خطط المعالجة. وأفهم أن لا يقتصر على وجود المستندات، بل يتأكد من أن الضوابط مطبقة وفعالة وتخفف المخاطر فعلياً. وأتطلع إلى توظيف هذه GRC دور المعرفة في دعم أهداف الجهة وتحسين مستوى نضجها السيبراني.

Model answer: I am a cybersecurity professional with a strong interest in governance, risk, and compliance because it connects business objectives, regulatory requirements, and technical controls. I have knowledge of risk assessments, control reviews, policy development, evidence collection, and remediation tracking. I understand that GRC is not only about documentation; it is about ensuring controls are implemented, effective, and genuinely reduce risk. I am looking to apply this approach to support the organization and improve its cybersecurity maturity.

تنبيه: اجعل الإجابة بين 60 و90 ثانية، وإذا لم تكن لديك خبرة وظيفية فاذكر المشاريع والتمارين العملية بوضوح.

Tip: Keep the answer within 60–90 seconds. If you are entry-level, refer honestly to projects, simulations, and academic work.

ما هو GRC

What is GRC?

ما الذي يقيسه السؤال: فهمك للصورة الكاملة وليس حفظ المصطلحات

What it assesses: Your understanding of the operating model, not just the acronym.

منهج يساعد المنظمة على تحقيق أهدافها بطريقة منظمة وأمنة. الحوكمة تحدد التوجه والمسؤوليات وآلية اتخاذ GRC: إجابة نموذجية القرار. إدارة المخاطر تحدد الأحداث التي قد تؤثر في الأهداف وكيفية التعامل معها. والامتثال يتأكد من الالتزام بالأنظمة واللوائح والعقود والسياسات الداخلية. القيمة الحقيقية تظهر عندما تعمل هذه العناصر معًا بدلاً من عمل كل عنصر بمعزل عن الآخر.

Model answer: GRC is an integrated approach that helps an organization achieve its objectives in a controlled and secure manner. Governance sets direction, accountability, and decision rights. Risk management identifies what may affect objectives and determines the appropriate response. Compliance ensures alignment with laws, regulations, contracts, and internal policies. The real value comes from integrating all three rather than treating them as separate activities.

ما الفرق بين Compliance و Risk و Governance

What is the difference between governance, risk, and compliance?

ما الذي يقيسه السؤال: قدرتك على التمييز بين الوظائف الثلاث وربطها

What it assesses: Your ability to distinguish and connect the three disciplines.

إجابة نموذجية: الحوكمة ترسم الاتجاه وتحدد من يقرر ومن يعتمد ومن يتحمل المسؤولية. إدارة المخاطر تساعد المنظمة على تحديد المخاطر وتحليلها وترتيب الأولويات واختيار المعالجة. والامتثال يحدد المتطلبات الملزمة وكيف نثبت تطبيقها. باختصار: الحوكمة توجه، والمخاطر ترتب الأولويات، والامتثال يثبت الالتزام.

Model answer: Governance defines direction, decision rights, approvals, and accountability. Risk management identifies, analyzes, prioritizes, and treats uncertainty that may affect objectives. Compliance identifies applicable obligations and demonstrates that they are being met. In short: governance directs, risk prioritizes, and compliance provides assurance.

كيف تجري تقييم مخاطر سيبرانية ؟

How do you perform a cybersecurity risk assessment?

ما الذي يقيسه السؤال :فهمك لدورة تقييم المخاطر من النطاق إلى المتابعة

What it assesses: Your command of the full risk assessment lifecycle.

إجابة نموذجية: أبدأ بتحديد النطاق والهدف وأصحاب المصلحة، ثم أحدد الأصول وقيمتها وأهميتها للأعمال. بعد ذلك أحدد التهديدات والثغرات والضوابط الحالية، وأقيم الاحتمالية والتأثير وفق منهجية الجهة. أحدد الخطر الكامن قبل الضوابط والخطر المتبقي بعدها، ثم أنفق مع مالك الخطر على خيار المعالجة والمالك والتاريخ المستهدف، وأوثق ذلك في سجل المخاطر مع مراجعة دورية أو عند حدوث تغيير جوهري.

Model answer: I start by defining the scope, objective, and stakeholders, then identify assets and their business criticality. I identify threats, vulnerabilities, and existing controls, and assess likelihood and impact using the organization's approved methodology. I determine inherent and residual risk, agree on a treatment plan with the risk owner, assign ownership and due dates, document the result in the risk register, and monitor it periodically or when material changes occur.

ما الفرق بين الخطر الكامن والخطر المتبقي؟

What is the difference between inherent and residual risk?

ما الذي يقيسه السؤال :فهمك لتأثير الضوابط على مستوى الخطر

What it assesses: Your understanding of how controls change risk exposure.

إجابة نموذجية: الخطر الكامن هو مستوى الخطر قبل أخذ الضوابط في الاعتبار. أما الخطر المتبقي فهو المستوى الذي يبقى بعد تطبيق الضوابط الحالية. إذا بقي الخطر المتبقي أعلى من شهية المخاطر، نحتاج إلى معالجة إضافية أو قبول رسمي من صاحب الصلاحية.

Model answer: Inherent risk is the level of exposure before considering controls. Residual risk is the exposure that remains after existing controls are applied. If residual risk remains above risk appetite, additional treatment or formal acceptance by the authorized risk owner is required.

ما خيارات معالجة المخاطر؟

What are the main risk treatment options?

ما الذي يقيسه السؤال: قدرتك على اختيار استجابة مناسبة وعدم تجاوز صلاحياتك

What it assesses: Your ability to select a suitable response without overstepping authority.

إجابة نموذجية: الخيارات الأساسية هي التقليل أو التجنب أو النقل أو القبول. الاختيار يعتمد على مستوى الخطر وشهية المخاطر وتكلفة وحده؛ بل يتم من مالك الخطر أو صاحب الصلاحية حسب حوكمة GRC المعالجة وأثرها على الأعمال. قبول الخطر ليس قرار موظف الجهة.

Model answer: The main options are mitigate, avoid, transfer, and accept. The choice depends on risk level, risk appetite, treatment cost, and business impact. Risk acceptance is not a decision made by the GRC analyst alone; it must be approved by the authorized risk owner according to governance requirements.

Threat وVulnerability وRisk ما الفرق بين

What is the difference between a threat, vulnerability, and risk?

ما الذي يقيسه السؤال: دقة مفاهيمك الأساسية في إدارة المخاطر

What it assesses: The accuracy of your foundational risk concepts.

إجابة نموذجية: التهديد هو مصدر أو حدث قادر على إحداث الضرر، والثغرة هي نقطة ضعف يمكن استغلالها، أما الخطر فهو احتمال استغلال التهديد للثغرة وما ينتج عنه من أثر. مثلاً: النظام غير المحدث ثغرة، وبرمجية الفدية تهديد، وتوقف الخدمة أو فقد البيانات هو سيناريو الخطر وتأثيره.

Model answer: A threat is a source or event capable of causing harm. A vulnerability is a weakness that can be exploited. Risk is the likelihood and impact of a threat exploiting a vulnerability. For example, an unpatched system is a vulnerability, ransomware is a threat, and service disruption or data loss represents the risk scenario and its impact.

Policy وStandard وProcedure ما الفرق بين

What is the difference between a policy, standard, and procedure?

ما الذي يقيسه السؤال :فهمك لهرم الوثائق وكيف تتحول السياسة إلى تنفيذ

What it assesses: Your understanding of the document hierarchy and operationalization.

إجابة نموذجية: السياسة تحدد التوجه العام وما الذي يجب الالتزام به .المعيار يحدد متطلبات إلزامية قابلة للقياس .والإجراء يشرح خطوات التنفيذ ومن ينفذها ومتى .أما الإرشادات فتعرض ممارسات موصى بها وقد تكون أقل إلزاماً

Model answer: A policy states management direction and what must be achieved. A standard defines mandatory and measurable requirements. A procedure explains how the requirement is performed, by whom, and when. Guidelines provide recommended practices and are generally less prescriptive.

كيف تقيس الالتزام بضابط؟

How do you assess compliance with a control?

ما الذي يقيسه السؤال :قدرتك على تحويل نص المتطلب إلى اختبار واضح

What it assesses: Your ability to translate a requirement into a clear test.

إجابة نموذجية: أفهم نص المتطلب وهدفه ونطاقه أولاً، ثم أحدد مالك الضابط والدليل المطلوب والعينة والفترة الزمنية .أراجع تصميم الضابط وهل يستطيع معالجة الخطر، ثم أختبر فعالية تشغيله .بعد ذلك أوثق النتيجة والدليل وأصنف حالة التطبيق حسب منهجية الجهة، وأحدد الفجوة وخطة المعالجة عند الحاجة

Model answer: I first understand the requirement, its objective, and scope. I identify the control owner, required evidence, sample, and review period. I assess whether the control is appropriately designed, then test whether it operated effectively. I document the conclusion and supporting evidence, assign the implementation status according to the organization's methodology, and record any gap and remediation plan.

ما الفرق بين تصميم الضابط وفعاليتّه التشغيلية؟

What is the difference between control design and operating effectiveness?

ما الذي يقيسه السؤال: قدرتك على التمييز بين وجود الضابط وعمله فعليًا

What it assesses: Your ability to distinguish control existence from actual performance.

إجابة نموذجية: فعالية التصميم تعني أن الضابط مصمم بطريقة تستطيع معالجة الخطر. أما الفعالية التشغيلية فتعني أنه يُنفذ فعليًا وباستمرار خلال الفترة المطلوبة. قد توجد سياسة ممتازة على الورق، لكن إذا لم تنفذ فالتصميم موجود والفعالية التشغيلية ضعيفة.

Model answer: Design effectiveness asks whether the control is capable of addressing the risk. Operating effectiveness asks whether the control was actually performed consistently over the required period. A well-written policy may demonstrate design intent, but if it is not implemented, operating effectiveness is weak.

ما الأدلة التي تطلبها لإثبات تطبيق الضابط؟

What evidence would you request to verify a control?

ما الذي يقيسه السؤال: قدرتك على اختيار أدلة موثوقة ومرتبطة بالمتطلب

What it assesses: Your ability to select reliable, relevant evidence.

إجابة نموذجية: يعتمد الدليل على طبيعة الضابط، وقد يشمل سياسة معتمدة أو إعدادات نظام أو سجلات تقنية أو تذاكر تغيير أو قوائم صلاحيات أو عينات مراجعة أو محاضر لجان أو نتائج اختبار. أفضل الدليل المستخرج من النظام أو من مصدر مستقل، وأتأكد من تاريخه ونطاقه ومالكه وسلامته وهل يثبت التطبيق المستمر وليس حالة لحظية فقط.

Model answer: Evidence depends on the control and may include approved policies, system configurations, logs, change tickets, access lists, review samples, committee minutes, or test results. I prefer evidence generated by the system or an independent source, and I verify its date, scope, owner, integrity, and whether it demonstrates consistent operation rather than a one-time snapshot.

اكتشفت ضابطاً غير مطبق، ماذا تفعل؟

What would you do if you found a control was not implemented?

ما الذي يقيسه السؤال :منهجك في التحقق والتوثيق والمعالجة والتصعيد

What it assesses: Your approach to validation, documentation, remediation, and escalation.

إجابة نموذجية: أتأكد من صحة الفجوة وأناقشها مع مالك الضابط لفهم السبب والضوابط التعويضية الموجودة. أقيم مستوى الخطر وأوثق الملاحظة والدليل، ثم ننفق على خطة معالجة بمالك وتاريخ مستهدف. أتابع التنفيذ وأتأكد من دليل الإغلاق. وإذا تأخرت المعالجة أو تجاوز الخطر المستوى المقبول أرفع الحالة وفق مسار التصعيد المعتمد.

Model answer: I validate the gap and discuss it with the control owner to understand the cause and any compensating controls. I assess the associated risk, document the issue and evidence, and agree on a remediation plan with an owner and due date. I monitor progress and verify closure evidence. If remediation is overdue or risk exceeds the acceptable level, I escalate according to the approved process.

ماذا تفعل إذا رفضت إدارة تنفيذ أحد الضوابط؟

How would you handle a business unit that refuses to implement a control?

ما الذي يقيسه السؤال :التواصل مع الأعمال وحل التعارض دون فقدان الاستقلالية

What it assesses: Business communication and conflict resolution without losing independence.

إجابة نموذجية: أفهم سبب الرفض أولاً؛ فقد يكون تقنياً أو مالياً أو تشغيلياً. أوضح الخطر والمتطلب وتأثير عدم التطبيق بلغة أعمال، ثم أبحث معهم عن حل بديل أو ضابط تعويضي. إذا بقي الخطر أعلى من المستوى المقبول أو كان المتطلب إلزامياً، أوثق الحالة وأرفعها وفق الحوكمة. هدفي أن يكون القرار واعياً وموثقاً وقابلًا للدفاع.

Model answer: I first understand the reason for resistance, which may be technical, financial, or operational. I explain the risk, requirement, and business impact in practical terms, then explore an alternative or compensating control. If risk remains above tolerance or the requirement is mandatory, I document and escalate according to governance. My goal is to support an informed, documented, and defensible decision.

Gap Assessment كيف تنفذ

How do you perform a gap assessment?

ما الذي يقيسه السؤال: قدرتك على إدارة تقييم امتثال منظم وقابل للتتبع

What it assesses: Your ability to run a structured and traceable compliance assessment.

إجابة نموذجية: أحدد النطاق والإطار التنظيمي والإصدار الصحيح، ثم أحول الضوابط إلى متطلبات قابلة للاختبار. أحدد المالك والدليل المطلوب لكل متطلب وأجمع الأدلة وأجري المقابلات. بعد ذلك أقيم حالة التطبيق وأوثق الفجوات والأسباب والمخاطر، ثم أرتب خطة المعالجة حسب الخطورة والمتطلبات الزمنية وأتابعها مع ملاك الإجراءات.

Model answer: I define the scope, applicable framework, and correct version, then translate controls into testable requirements. I identify owners and required evidence, collect documentation, and conduct interviews. I assess implementation status, document gaps, causes, and risks, then prioritize the remediation plan based on risk and deadlines and track actions with accountable owners.

كيف تقيم مخاطر طرف ثالث أو مورد؟

How do you assess third-party or vendor risk?

ما الذي يقيسه السؤال: فهمك لدورة مخاطر المورد قبل التعاقد وأثناءه وبعده

What it assesses: Your understanding of vendor risk across the relationship lifecycle.

إجابة نموذجية: أصنف المورد بناءً على حساسية الخدمة والبيانات ومدى الاعتماد التشغيلي عليه، ثم أراجع الاستبيان الأمني والأدلة والشهادات ونتائج الاختبارات. أتأكد من تضمين متطلبات الأمن والخصوصية والإبلاغ عن الحوادث وحقوق التدقيق واستمرارية الأعمال وإنهاء العلاقة في العقد. أحدد مستوى الخطر وخطة المعالجة ثم أتابع المورد دورياً وليس عند بداية التعاقد فقط.

Model answer: I classify the vendor based on service criticality, data sensitivity, and operational dependency. I review security questionnaires, evidence, certifications, and test results. I verify that contracts address security, privacy, incident notification, audit rights, business continuity, and exit requirements. I determine the risk level and treatment plan and continue monitoring throughout the relationship, not only during onboarding.

مورد أبلغكم عن حادثة تسرب بيانات، ماذا تفعل؟

A vendor reports a data breach. What do you do?

ما الذي يقيسه السؤال: قدرتك على تنسيق الاستجابة والالتزامات دون القفز إلى استنتاجات

What it assesses: Your ability to coordinate response and obligations without premature conclusions.

إجابة نموذجية: أفعل مسار إدارة حوادث الطرف الثالث وأتحقق من وقت الاكتشاف والإبلاغ ونوع البيانات والنطاق والأنظمة والأطراف المتأثرة. أحافظ على الأدلة وأشرك الأمن السيبراني والقانوني والخصوصية والامتثال والأعمال حسب الخطة. أراجع الالتزامات التنظيمية والتعاقدية ومواعيد الإبلاغ، وأوثق القرارات وأتابع الاحتواء والتحقيق والتعافي والدروس المستفادة وتحديث تقييم مخاطر المورد.

Model answer: I activate the third-party incident process and confirm detection and notification times, data types, scope, systems, and affected parties. I preserve evidence and engage cybersecurity, legal, privacy, compliance, and business teams according to the response plan. I review regulatory and contractual notification obligations, document decisions, and track containment, investigation, recovery, lessons learned, and the updated vendor risk assessment.

تنبيه: لا تتخذ قرار الإبلاغ التنظيمي منفردًا؛ اشرح أنك تجمع الحقائق وتنسق مع أصحاب الصلاحية.

Tip: Do not claim that you would make the regulatory notification decision alone; emphasize fact gathering and coordination with authorized stakeholders.

كيف تتعامل مع استثناء أمني؟

How do you manage a security exception?

ما الذي يقيسه السؤال: فهمك للقبول المؤقت للمخاطر وضوابطه

What it assesses: Your understanding of temporary risk acceptance and its governance.

إجابة نموذجية: يوثق صاحب الطلب سبب الاستثناء ونطاقه ومدته والأنظمة المتأثرة. أقيم الخطر وأحدد ضوابط تعويضية، ثم أحصل على موافقة مالك الخطر وصاحب الصلاحية. يجب أن يكون للاستثناء تاريخ انتهاء واضح ومراجعة قبل التجديد، وألا يتحول الحل المؤقت إلى وضع دائم بلا متابعة.

Model answer: The requester documents the reason, scope, duration, and affected systems. I assess the risk, identify compensating controls, and obtain approval from the authorized risk owner. The exception must have a clear expiry date and be reviewed before renewal so that a temporary workaround does not become a permanent unmanaged condition.

كيف ترتب الفجوات إذا كانت كثيرة؟

How do you prioritize a large number of gaps?

ما الذي يقيسه السؤال: قدرتك على اتخاذ الأولويات وفق المخاطر والأعمال

What it assesses: Your ability to prioritize using risk and business context.

إجابة نموذجية: أرتب الفجوات بحسب مستوى الخطر والزامية المتطلب وحساسية الأصول وتأثيرها على الأعمال وسهولة الاستغلال ووجود ضوابط تعويضية والموعود التنظيمي. أبدأ بالمخاطر الحرجة والمكاسب السريعة، ثم أبني خطة مرحلية تتضمن المالك والموعود والاعتماديات ومؤشرات المتابعة.

Model answer: I prioritize gaps based on risk level, mandatory obligations, asset criticality, business impact, exploitability, compensating controls, and regulatory deadlines. I address critical exposures and appropriate quick wins first, then build a phased plan with owners, due dates, dependencies, and monitoring indicators.

ما مؤشرات الأداء المناسبة لـ GRC

Which GRC metrics would you use?

ما الذي يقيسه السؤال: قدرتك على قياس الفعالية لا حجم النشاط فقط

What it assesses: Your ability to measure outcomes rather than activity alone.

إجابة نموذجية: أستخدم مؤشرات مثل نسبة الضوابط المطبقة والفعالة، وعدد المخاطر الحرجة المتجاوزة لتاريخ المعالجة، ومتوسط مدة إغلاق الفجوات، ونسبة تقييم الموردين مرتفعي الخطورة، وعدد الاستثناءات المنتهية، ونسبة خطط المعالجة المتأخرة، وتكرار الملاحظات التدقيقية. وأربطها بمستوى الخطر المتبقي وشهية المخاطر حتى تعكس الأثر الحقيقي.

Model answer: I use metrics such as the percentage of implemented and effective controls, overdue critical risks, average remediation time, completion of high-risk vendor assessments, expired exceptions, overdue treatment plans, and repeat audit findings. I connect these metrics to residual risk and risk appetite so they reflect outcomes rather than the volume of activity.

ما الأطر والمعايير التي تعرفها؟

Which frameworks and standards are you familiar with?

ما الذي يقيسه السؤال: معرفتك بالأطر وقدرتك على اختيار ما ينطبق

What it assesses: Your knowledge of frameworks and ability to determine applicability.

إجابة نموذجية: اختيار الإطار يعتمد على نوع الجهة والقطاع والنطاق. في السعودية من المهم فهم

وما ينطبق من ضوابط الهيئة الوطنية للأمن السيبراني. في القطاع المالي تراعى متطلبات البنك المركزي السعودي، ECC 2:2024 لتنظيم القدرات والممارسات. الأهم NIST CSF لبناء نظام إدارة أمن المعلومات ومن ISO/IEC 27001 ويمكن الاستفادة من. عندي ليس سرد الأسماء، بل تحديد نطاق الانطباق وتحويل المتطلبات إلى ضوابط وأدلة واختبارات وخطط معالجة

Model answer: Framework selection depends on the organization, sector, and scope. In Saudi Arabia, it is important to understand ECC 2:2024 and other applicable NCA controls. Financial institutions must consider Saudi Central Bank requirements. ISO/IEC 27001 can support an information security management system, while NIST CSF can organize cybersecurity capabilities and practices. The key is not listing frameworks; it is determining applicability and translating requirements into controls, evidence, tests, and remediation plans.

ماذا تعرف عن NCA ECC ؟

What do you know about the NCA Essential Cybersecurity Controls?

ما الذي يقيسه السؤال: استعدادك للعمل ضمن السياق التنظيمي السعودي

What it assesses: Your readiness to work within the Saudi regulatory context.

إجابة نموذجية: الضوابط الأساسية للأمن السيبراني

تغطي خمسة مجالات رئيسية: حوكمة الأمن السيبراني، وتعزيز الأمن السيبراني، وصمود الأمن السيبراني، والأمن ECC 2:2024 السيبراني المتعلق بالأطراف الخارجية والحوسبة السحابية، والأمن السيبراني لأنظمة التحكم الصناعي عند انطباقه. عند التطبيق أحدد النطاق ومالك كل ضابط والأدلة والفجوات وخطط المعالجة، ولا أتعامل معها كقائمة تحقق شكلية

Model answer: The NCA Essential Cybersecurity Controls, ECC 2:2024, cover five main domains: cybersecurity governance, cybersecurity defense, cybersecurity resilience, third-party and cloud computing cybersecurity, and industrial control systems cybersecurity where applicable. In practice, I determine scope, assign control ownership, identify evidence, assess gaps, and track remediation rather than treating the controls as a superficial checklist.

ما علاقة الحوكمة والمخاطر والامتثال في حماية البيانات الشخصية؟

How does GRC relate to the Personal Data Protection Law?

ما الذي يقيسه السؤال: فهمك للتقاطع بين الأمن السيبراني والخصوصية

What it assesses: Your understanding of the intersection between cybersecurity and privacy.

إجابة نموذجية: يتقاطع GRC

مع الخصوصية في تصنيف البيانات وإدارة الوصول والاحتفاظ بالبيانات والأطراف الخارجية والحوادث. أعمل بالتنسيق مع مسؤول الخصوصية والقانوني لتحديد المتطلبات وتقييم الضوابط وجمع الأدلة. ولا أفترض أن الخصوصية مسؤولية فريق الأمن وحده؛ فهي مسؤولية مشتركة بين عدة إدارات.

Model answer: GRC intersects with privacy in data classification, access management, retention, third parties, and incident response. I coordinate with privacy and legal stakeholders to determine obligations, assess controls, and collect evidence. Privacy is not owned by cybersecurity alone; it requires shared accountability across multiple functions.

ما دور GRC أثناء الحوادث السيبرانية؟

What is the role of GRC during a cybersecurity incident?

ما الذي يقيسه السؤال: فهمك لحدود الدور والتنسيق مع الفرق الفنية

What it assesses: Your understanding of role boundaries and cross-functional coordination.

إجابة نموذجية: فريق GRC

لا يقوم عادة بالاحتواء التقني أو التحليل الجنائي بنفسه، لكنه يتحقق من اتباع خطة الاستجابة ويحدد الالتزامات التنظيمية والتعاقدية ويساعد في توثيق القرارات وحفظ الأدلة والتنسيق مع أصحاب المصلحة. وبعد الحادث يتابع الإجراءات التصحيحية وتحديث المخاطر والسياسات والضوابط.

Model answer: GRC does not usually perform technical containment or digital forensics. It helps ensure the response plan is followed, identifies regulatory and contractual obligations, supports decision documentation and evidence preservation, and coordinates stakeholders. After the incident, GRC tracks corrective actions and updates risks, policies, and controls.

طلب منك المدير تحقيق امتثال كامل خلال شهر، ماذا تقول؟

Your manager asks for full compliance within one month. How do you respond?

ما الذي يقيسه السؤال: واقعيتك وقدرتك على إدارة التوقعات دون تعطيل العمل

What it assesses: Your realism and ability to manage expectations constructively.

إجابة نموذجية: أحدد النطاق والحالة الحالية أولاً لأن نسبة الامتثال بلا تقييم وأدلة قد تكون مضللة. أنفذ تقييماً أولياً وأحدد الفجوات الحرجة والمتطلبات الإلزامية والمكاسب السريعة، ثم أعرض خطة مرحلية بالمالكين ومواعيد ومخاطر واضحة. قد نرفع مستوى الامتثال خلال شهر، لكن لا أعد بامتثال كامل قبل معرفة الفجوات والتحقق من فعالية الضوابط.

Model answer: I would first establish scope and the current state because a compliance percentage without assessment and evidence may be misleading. I would conduct an initial assessment, identify critical gaps, mandatory requirements, and quick wins, then present a phased plan with owners, dates, and clear risks. We may significantly improve compliance within a month, but I would not promise full compliance before understanding gaps and verifying control effectiveness.

كيف تشرح خطراً تقنياً للإدارة التنفيذية؟

How do you explain a technical risk to executives?

ما الذي يقيسه السؤال: قدرتك على تحويل التقنية إلى قرار أعمال

What it assesses: Your ability to translate technical detail into a business decision.

إجابة نموذجية: أبتعد عن التفاصيل غير الضرورية وأشرح الأصل أو الخدمة المتأثرة، وسيناريو الخطر، واحتمالية الحدوث، والأثر المالي أو التشغيلي أو التنظيمي أو السمعة، والضوابط الحالية والخيارات المتاحة وتكلفتها. أنهي بتوصية واضحة والقرار المطلوب من الإدارة.

Model answer: I avoid unnecessary technical detail and explain the affected asset or service, the risk scenario, likelihood, financial, operational, regulatory, or reputational impact, current controls, available options, and their cost. I conclude with a clear recommendation and the decision required from leadership.

ما خطتك لأول 90 يوماً؟

What would your first 90 days look like?

ما الذي يقيسه السؤال: قدرتك على البدء المنظم وتقديم قيمة مبكرة

What it assesses: Your ability to onboard methodically and create early value.

إجابة نموذجية: في أول 30 يوماً أفهم أعمال الجهة وهيكل الحوكمة والأطر المطبقة وأصحاب المصلحة وسجل المخاطر والملاحظات المفتوحة. وبين اليوم 31 و60 أراجع الأولويات والأدلة وملاك الضوابط وأحدد فجوات سريعة التحسين. وبين اليوم 61 و90 أقدم خطة متابعة واضحة ولوحة مؤشرات وأغلق ما يمكن من إجراءات ذات أولوية مع توثيق النتائج والدروس المستفادة.

Model answer: During the first 30 days, I would understand the business, governance structure, applicable frameworks, stakeholders, risk register, and open findings. From days 31 to 60, I would validate priorities, evidence, and control ownership and identify practical quick wins. From days 61 to 90, I would establish a clear tracking plan and metrics, close priority actions where possible, and document results and lessons learned.

لماذا نختارك لهذه الوظيفة؟

Why should we hire you for this role?

ما الذي يقيسه السؤال: قيمة ما ستضيفه ومدى ارتباطه باحتياج الوظيفة

What it assesses: The value you offer and its relevance to the role.

إجابة نموذجية: لأنني أتعامل مع الحوكمة والمخاطر والامتثال كحلقة وصل بين المتطلبات والمخاطر والتقنية والأعمال. أستطيع فهم GRC المتطلب وتحويله إلى ضوابط قابل للتطبيق وتحديد الأدلة وتوثيق الفجوات بوضوح. كما أركز على التواصل والمتابعة لأن نجاحي يعتمد على تعاون الإدارات. وأقيس جودة العمل بخفض المخاطر وتحسين فعالية الضوابط، وليس بعدد المستندات فقط.

Model answer: Because I approach GRC as the connection between requirements, risk, technology, and business objectives. I can interpret a requirement, translate it into an implementable control, identify appropriate evidence, and document gaps clearly. I also focus on communication and follow-up because GRC succeeds through cross-functional cooperation. I measure quality by reduced risk and improved control effectiveness, not by the number of documents produced.

أسئلة سلوكية حضر لها أمثلة | Behavioral Questions to Prepare

1. احكِ عن موقف واجهت فيه مقاومة من إحدى الإدارات وكيف تعاملت معها.

Tell us about a time you faced resistance from a business unit and how you handled it.

2. صف مشروعًا كان وقته ضيقًا وكيف رتب الأولويات.

Describe a time-sensitive project and how you prioritized the work.

3. ماذا تفعل إذا اكتشفت خطأ في تقرير سبق أن أرسلته.

What would you do if you discovered an error in a report you had already submitted?

4. احكِ عن اختلاف مهني مع مدقق أو مالك ضابط.

Tell us about a professional disagreement with an auditor or control owner.

5. كيف تعاملت مع عدة مهام عالية الأولوية في الوقت نفسه.

How did you manage several high-priority tasks at the same time?

6. أعط مثالًا على شرحك لموضوع تقني لشخص غير تقني.

Give an example of explaining a technical issue to a non-technical stakeholder.

أسئلة تسألها أنت في نهاية المقابلة | Questions You Should Ask at the End

1. ما الأطر التنظيمية الرئيسية المطبقة لدى الجهة؟

1. Which regulatory frameworks are most relevant to this organization?

2. حاليًا؟ GRC ما أكبر تحدٍ يواجه فريق

2. What is the biggest challenge currently facing the GRC team?

3. هل يركز الدور أكثر على المخاطر أم الامتثال أم تدقيق الضوابط أم الأطراف الخارجية؟

3. Does the role focus primarily on risk, compliance, control assurance, or third-party risk?

4. كيف تقيسون نجاح الموظف خلال أول ثلاثة أشهر؟

4. How do you measure success during the first three months?

5. ما الأنظمة والأدوات المستخدمة لإدارة المخاطر والامتثال والأدلة؟

5. Which systems and tools are used to manage risk, compliance, and evidence?

أخطاء شائعة تجنبها | Common Mistakes to Avoid

العربية	English
إعطاء تعريفات محفوظة بلا مثال أو تطبيق	Giving memorized definitions without practical application.
الخلط بين الخطر والثغرة والتهديد	Confusing risk, vulnerability, and threat.
اعتبار وجود السياسة دليلاً كافياً على فعالية الضابط	Treating the existence of a policy as sufficient proof of control effectiveness.
يقبل المخاطر بنفسه GRC القول إن موظف	Claiming that the GRC analyst personally accepts risk.
التعامل مع الامتثال كقائمة تحقق شكلية	Treating compliance as a superficial checklist.
ذكر أطر كثيرة دون القدرة على شرح كيفية اختبار ضابط	Listing many frameworks without being able to explain how to test a control.
ادعاء خبرة أو مسؤوليات لم تمارسها	Claiming experience or responsibilities you do not have.
تقديم توصية بلا مالك أو موعد أو دليل إغلاق	Proposing remediation without an owner, due date, or closure evidence.

المراجع الرسمية | Official References

الهيئة الوطنية للأمن السيبراني – الضوابط الأساسية للأمن السيبراني

ECC 2:2024 | NCA – Essential Cybersecurity Controls ECC 2:2024

<https://nca.gov.sa/en/regulatory-documents/controls-list/ecc/>

البنك المركزي السعودي – إطار الأمن السيبراني

Saudi Central Bank – Cyber Security Framework

<https://rulebook.sama.gov.sa/en/cyber-security-framework-2>

منصة حوكمة البيانات الوطنية – نظام حماية البيانات الشخصية

National Data Governance Platform – Personal Data Protection Law

<https://dgp.sdaia.gov.sa/wps/portal/pdp/knowledgecenter/PoliciesAndRegulations/>

تواصل معي | Connect With Me

المنصة Platform	الحساب Account
X	@Ralghanmi
Snapchat	Rmoii
TikTok / Instagram / YouTube	@Cyber4alll
LinkedIn	Rami Alghanmi رامي الغانمي

متابعة قناة الامن السيبراني للجميع على واتساب

<https://whatsapp.com/channel/0029Vb69Mn33AzNZb7ZI0d0d>

قناة التليجرام العامة

<https://t.me/cyber4alll>

This guide is general educational material. Tailor all answers to your actual experience, the job description, and the organization's requirements.